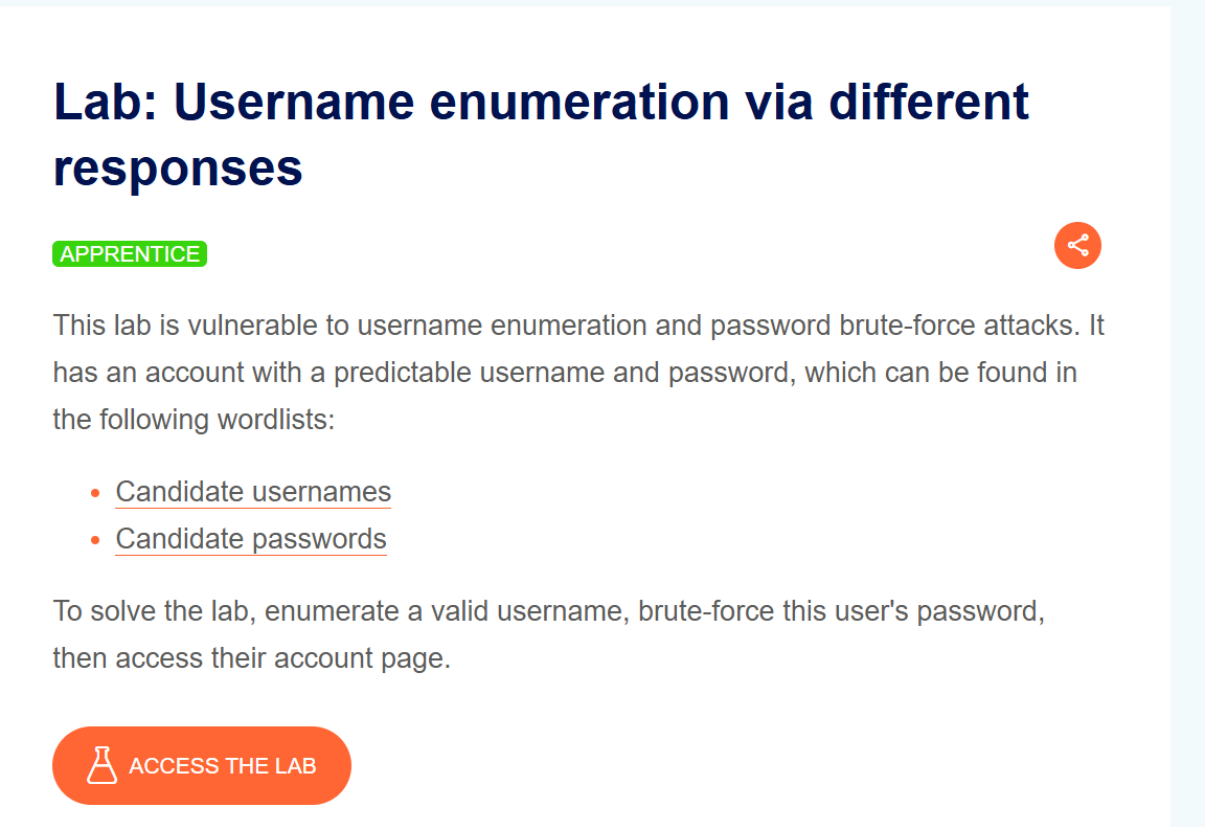
Day 32 – Authentication: User Enumeration Lab

STEPS

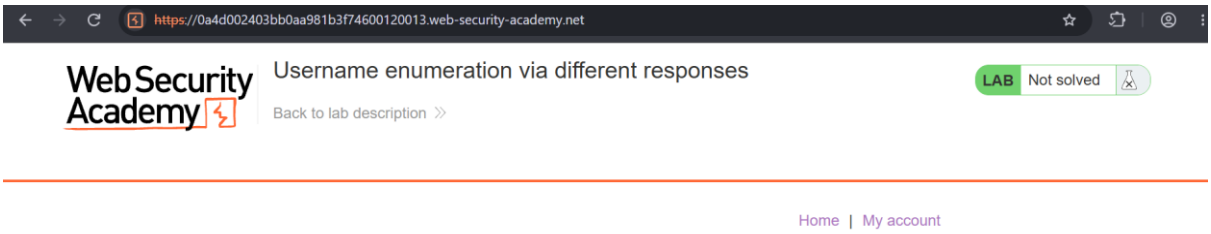
1. Open the provided PortSwigger authentication lab.



2. Launch the lab environment.

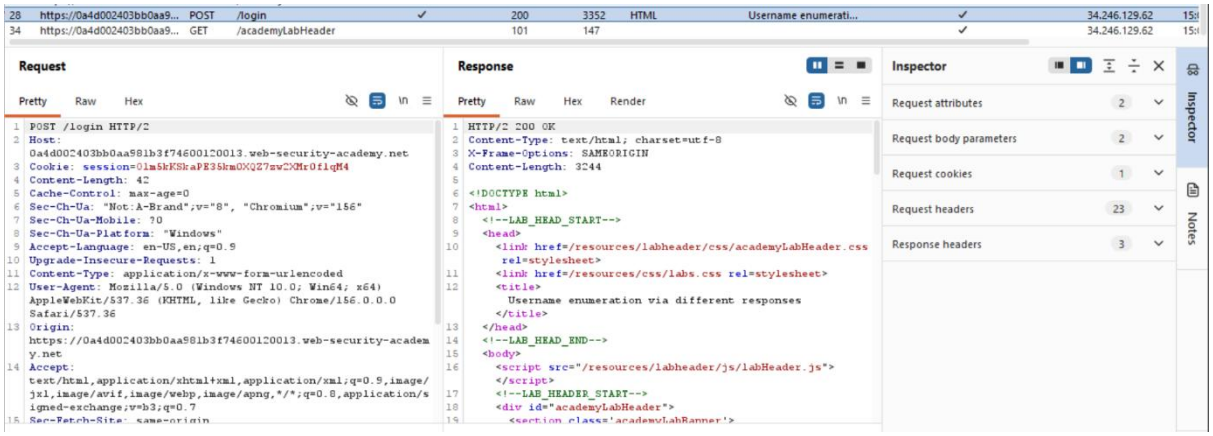


3. Configure/open Burp Suite.

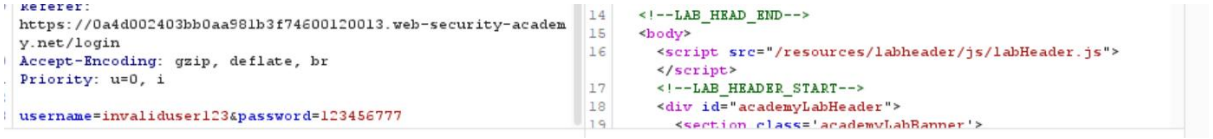


4. Observe the login request.

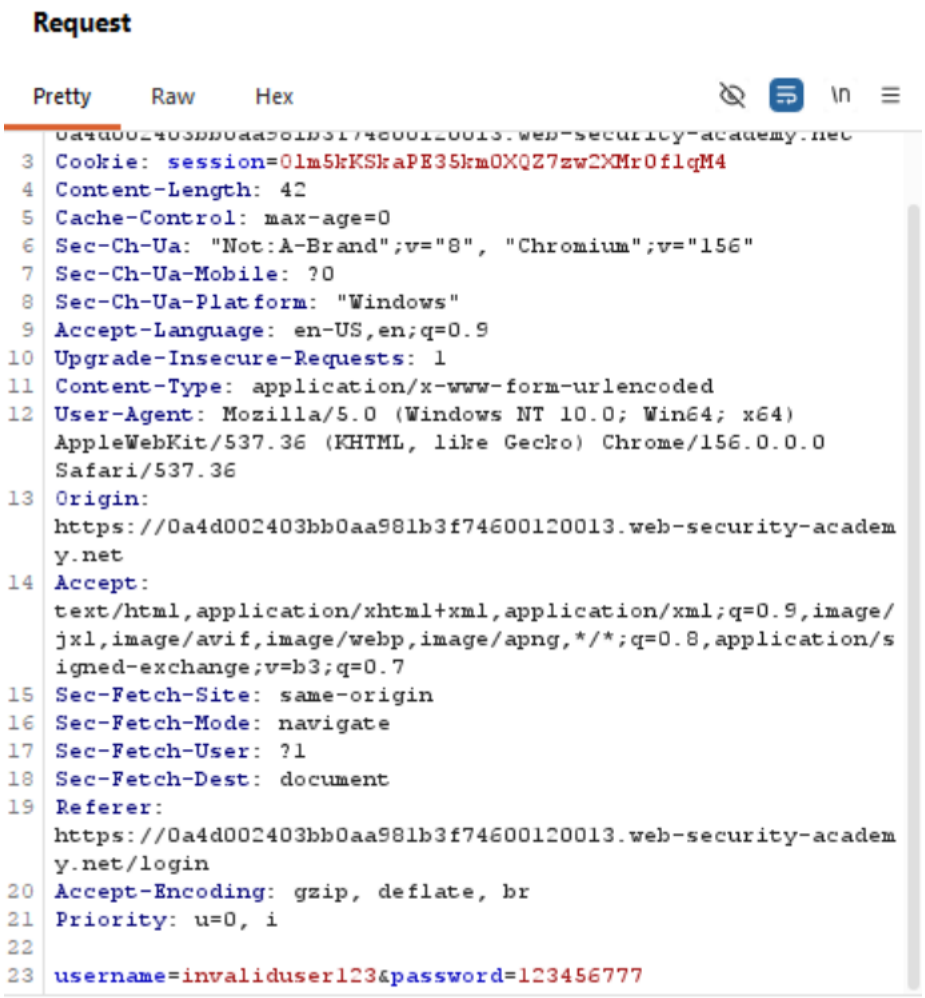
Day 32 – Authentication: User Enumeration Lab



5. Submit intentionally invalid credentials in the training application.



6. Find the login POST request in Burp Proxy / HTTP History.

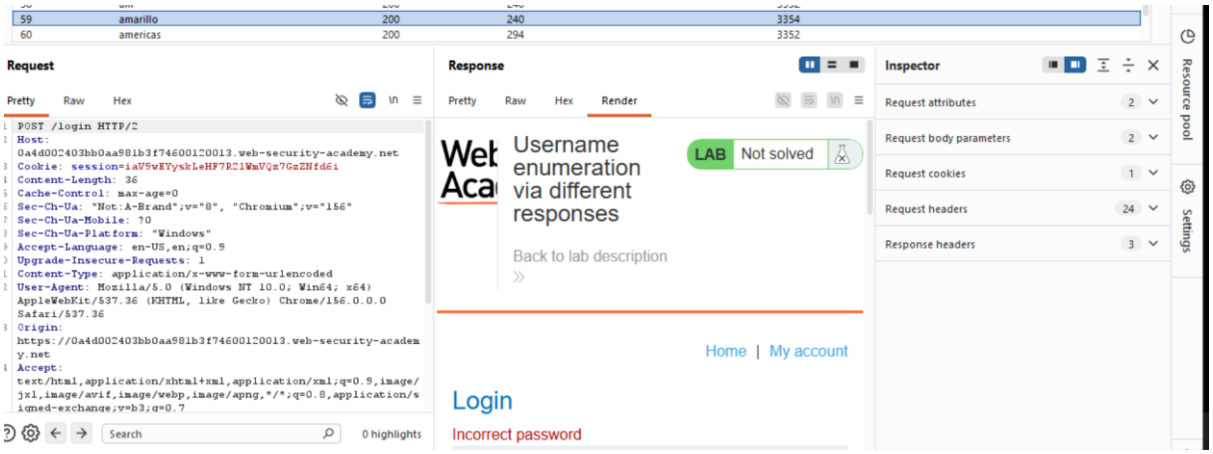


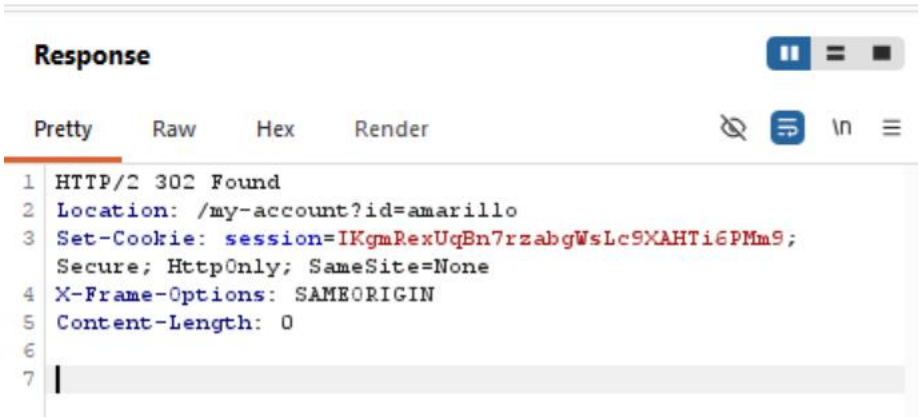
Day 32 – Authentication: User Enumeration Lab

7. Compare authentication responses.

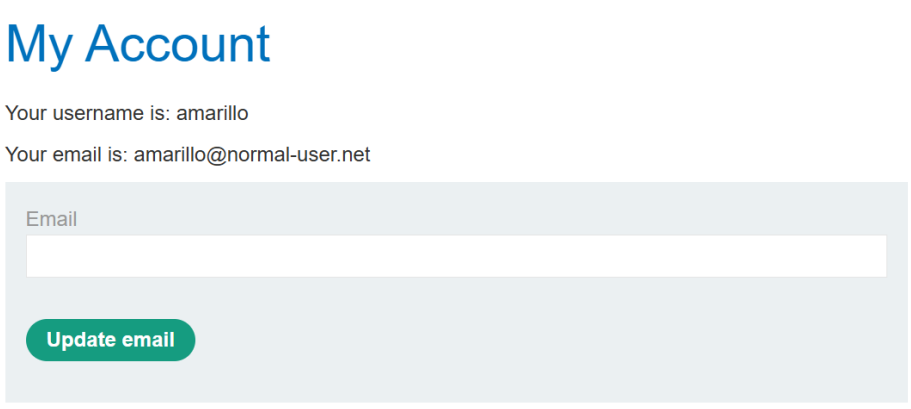
8. Observe differences such as: message text, response length, status code, redirect behavior.

9. Determine why these differences may reveal whether a username is valid.



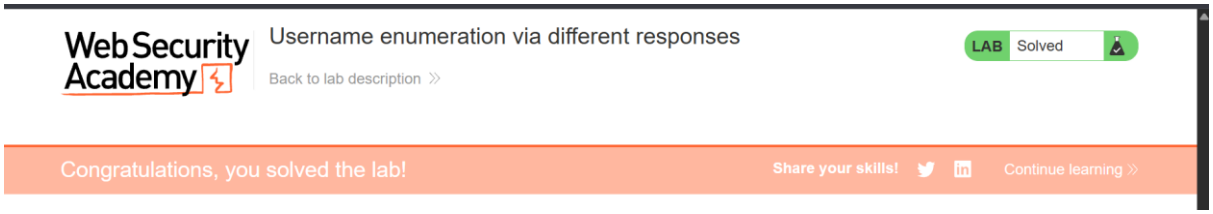


10. Complete the PortSwigger lab only inside the provided training environment.



11. Record evidence/screenshots.

Day 32 – Authentication: User Enumeration Lab



12. Explain how developers could mitigate the weakness.

- Generic error messages: Display the same login error for invalid usernames and incorrect passwords to prevent username enumeration.
- Rate limiting: Limit repeated login attempts and introduce temporary account lockouts or delays to reduce brute-force attacks.
- Multi-factor authentication (MFA): Require an additional verification factor to protect accounts even if passwords are discovered.